

Secure Admin Authentication System - Implementation Summary

Overview

Implemented a production-ready secure authentication system for the admin panel using NextAuth.js v5 and Supabase, replacing the insecure localStorage-based password system.

What Was Implemented

1. Database Setup

Created `admin_users` table in Supabase:

- Fields: `id`, `email`, `password_hash`, `role`, `created_at`, `updated_at`, `last_login_at`, `failed_login_attempts`, `locked_until`, `is_active`
- Security features:
 - Passwords hashed with bcrypt (12 rounds)
 - Account lockout after 5 failed attempts (30 minutes)
 - Login attempt tracking
 - Role-based access (`admin`, `super_admin`)
- RLS policies updated to allow authentication access

SQL Files:

- `supabase-admin-users.sql` - Initial table creation
- `supabase-rls-fix.sql` - RLS policy fixes for authentication

2. Authentication System

NextAuth.js Configuration (`lib/auth.ts`):

- Credentials provider for email/password authentication
- Password verification with bcrypt
- Failed login attempt tracking
- Account lockout logic
- Session management (30-day expiration)
- JWT callbacks for user role management

Type Definitions (`types/next-auth.d.ts`):

- Extended NextAuth types for user role and ID

3. Admin User Management

Admin Creation Script (`scripts/create-admin.ts`):

- CLI tool to create admin users securely
- Password hashing with bcrypt
- Checks for existing users before insertion

Created Admin User:

- Email: `sylviane.paris_dickson@yahoo.com`

- Password: `Syldick123`
- Role: `super_admin`

4. UI Components

Login Page (`app/[locale]/admin/login/page.tsx`):

- Secure login form with email/password
- Error handling and loading states
- Client-side authentication using `next-auth/react`

Updated Admin Orders Page (`app/[locale]/admin/orders/page.tsx`):

- Uses NextAuth session management
- Redirects unauthenticated users to login
- Logout with NextAuth `signOut`

5. Route Protection

Middleware (`proxy.ts`):

- Protects all admin routes except login page
- Redirects unauthenticated users to localized login page
- Integrated with `next-intl` for internationalization
- Supports locale prefixes (`en`, `fr`, `es`)

6. Security Headers

Next.js Config (`next.config.ts`):

- HSTS (Strict-Transport-Security)
- X-Frame-Options (SAMEORIGIN)
- X-Content-Type-Options (nosniff)
- X-XSS-Protection
- Referrer-Policy
- Permissions-Policy (restricts camera, microphone, geolocation)

7. Session Provider

Layout (`app/[locale]/layout.tsx`):

- Added `SessionProvider` to wrap entire application
- Enables `useSession` and `signIn` hooks throughout the app

Files Created

1. `lib/auth.ts` - NextAuth configuration
2. `types/next-auth.d.ts` - TypeScript type definitions
3. `app/api/auth/[...nextauth]/route.ts` - NextAuth API route
4. `scripts/create-admin.ts` - Admin user creation script
5. `app/[locale]/admin/login/page.tsx` - Login page
6. `supabase-admin-users.sql` - Database table creation
7. `supabase-rls-fix.sql` - RLS policy fixes

Files Modified

1. `app/[locale]/admin/orders/page.tsx` - Updated to use NextAuth
 2. `proxy.ts` - Added auth middleware (replaced `middleware.ts`)
 3. `next.config.ts` - Added security headers
 4. `app/[locale]/layout.tsx` - Added `SessionProvider`
 5. `middleware.ts` - Deleted (merged into `proxy.ts`)
-

Environment Variables

Required in `.env.local` and Vercel:

```
NEXTAUTH_SECRET=oJYbtU6Y5aAbDgeMZy/XQkdmRQ7LdeRqJ6d058fkOCY=
```

Existing variables (already configured):

```
NEXT_PUBLIC_SUPABASE_URL=https://edpbkxlcapjmynahvgth.supabase.co
NEXT_PUBLIC_SUPABASE_ANON_KEY=eyJhbGciOiJIUzI1NiIsInR5cCI6IkpXVCJ9...
```

Installation Commands

Dependencies installed:

```
npm install next-auth bcryptjs
npm install -D @types/bcryptjs
```

Usage Instructions

Creating New Admin Users

```
npx tsx scripts/create-admin.ts <email> <password> [role]
```

Example:

```
npx tsx scripts/create-admin.ts admin@example.com securepassword super_admin
```

Accessing Admin Panel

1. Navigate to `/en/admin/login` (or `/fr/admin/login` , `/es/admin/login`)
2. Enter email and password
3. Upon successful login, redirect to `/en/admin/orders`

Admin URLs

- Login: `https://yourdomain.com/en/admin/login`
 - Orders: `https://yourdomain.com/en/admin/orders`
-

Security Features

✔ Passwords hashed with bcrypt (12 rounds) ✔ Account lockout after 5 failed attempts (30 minutes) ✔ Secure HTTP-only session cookies ✔ Session expiration (30 days) ✔ Route protection via middleware ✔ Security headers (HSTS, CSP, etc.) ✔ Failed login attempt tracking ✔ Last login timestamp ✔ Role-based access control ✔ Database-backed authentication (no localStorage)

Deployment Notes

Vercel Setup

1. Add `NEXTAUTH_SECRET` to Vercel environment variables
 - Go to Vercel Dashboard → Settings → Environment Variables
 - Add: `NEXTAUTH_SECRET=oJYbtU6Y5aAbDgeMZy/XQkdmRQ7LdeRqJ6d058fkOCY=`
 - Select all environments (Production, Preview, Development)
2. Run the SQL migrations in Supabase:
 - `supabase-admin-users.sql`
 - `supabase-rls-fix.sql`
3. Deploy - Vercel will automatically build and deploy

Troubleshooting

Login not working:

- Check browser console for errors
- Verify `NEXTAUTH_SECRET` is set in environment variables
- Ensure RLS policies are applied in Supabase
- Check that admin user exists in database

404 on admin routes:

- Ensure you're using locale-prefixed URLs (e.g., `/en/admin/orders`)
- Check middleware configuration
- Verify `proxy.ts` is correctly configured

Testing

Local Testing:

```
npm run dev
# Navigate to http://localhost:3000/en/admin/login
```

Production Testing:

- Deploy to Vercel
- Navigate to `https://yourdomain.com/en/admin/login`
- Test with admin credentials

Next Steps (Optional Enhancements)

1. Add email verification for new admin users

2. Implement password reset functionality
 3. Add two-factor authentication (2FA)
 4. Create admin user management UI
 5. Add audit logging for admin actions
 6. Implement IP-based rate limiting
 7. Add CAPTCHA for login attempts
-

Support

For issues or questions:

- Check browser console for specific error messages
 - Review Vercel deployment logs
 - Verify Supabase RLS policies
 - Ensure all environment variables are set
-

Implementation Date: September 29, 2026 **Status:**  Complete and Deployed